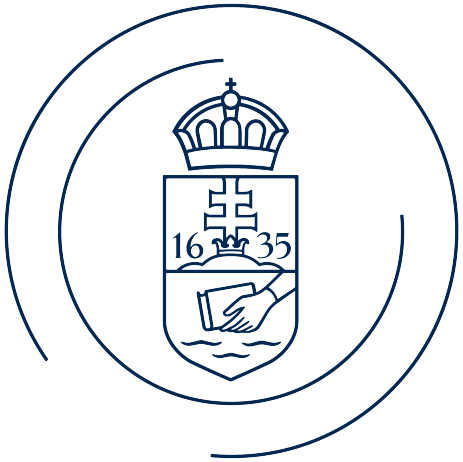


ELTE
EÖTVÖS LORÁND
UNIVERSITY

10101101001010101011101011010010101010111011101011010010101010100

Cybersecurity Basics

Basic Concepts of Cybersecurity

Key players and associated terminology

What you will learn...



- Core cybersecurity concepts: threats, vulnerabilities, incidents, and impacts
- The CIA Triad: Confidentiality, Integrity, Availability
- The cybersecurity cube: CIA vs Data states vs Mitigation
- Types of threat actors: Script kiddies, hacktivists, cybercriminals, state-sponsored actors
- Security controls: Preventing threat scenarios and mitigating impacts
- Hacker classifications: Black hats, white hats, gray hats, red hats, green hats, and blue hats

In a Nutshell: Cybersecurity

Definition: Cybersecurity

Cybersecurity is the protection of **information assets** from harm that may result in unauthorized disclosure of information, corruption of data and software, or disruption of the services they provide

- Information assets can be devices, applications, networks, data, and even users.
- These assets become exposed to potential cyber threats, human error, technical faults, systematic errors, or natural events.
- Critical infrastructure (energy, communications, transport) relies on IT systems.
- Cybersecurity has become critical for the global economy, politics, national security, organizations, and individuals.

ISO/IEC 27000 Perspective

Definition: Information Security (ISO/IEC 27000)

"Information security is the preservation of confidentiality, integrity, and availability of information. In addition, other properties, such as authenticity, accountability, non-repudiation, and reliability can also be involved."

- These additional properties (*authenticity*, *accountability*, *non-repudiation*, *reliability*) are often viewed as **security controls**.
- In practice, we protect not just the data but also the **resources** used to store and process data (i.e., *information assets*).

The CIA Triad



The CIA Triad

Confidentiality, **Integrity**, and **Availability** (*CIA*) are the **classic** security goals.

- **Confidentiality**: Preventing unauthorized disclosure of information.
- **Integrity**: Preventing unauthorized modification of information, ensuring correctness and trustworthiness.
- **Availability**: Ensuring systems and data are accessible to authorized users when needed.

Confidentiality: Definition & Importance

Definition

Confidentiality is the property that information is not made available or disclosed to *unauthorized* individuals, entities, or processes. *(ISO/IEC 27000)*

- **Key Point:** The term "unauthorized" is critical — if we do not know who has legitimate permission, then "confidentiality" loses its meaning.
- All organizations and individuals must protect sensitive information from unintended disclosure.
- **General threats to confidentiality:** *Data theft* committed by external actors, or *"data leakage"* caused by internal actors, either accidentally or intentionally. If it is intentional, then it is called an "*insider threat*".

Confidentiality: Preventing unauthorized disclosure

Controlling Access

Access control defines a number of protection schemes that prevent unauthorized access to a computer, network, database, or other data resources. The concepts of AAA involve three security services: Authentication, Authorization and Accounting.

- **Access Control** (AAA):
  - **Authentication** – Verifies a user's identity to prevent unauthorized access
  - **Authorization** – Determines which resources users can access, along with the operations that users can perform. Authorization can also control when a user has access to a specific resource.
  - **Accounting** – Keeps track of what users do, including what they access, the amount of time they access resources, and any changes made.

AAA



Authentication

Who are you?

Authorization

How much can you spend?

Accounting

What did you spend it on?

Account Number	Statement Closing Date	Current Amount Due
1234-567-890	01-31-01	$278.50

JOE EMPLOYEE
456 SKYVIEW DRIVE
HOMETOWN, USA 99900-1234

MAIL PAYMENT TO :
THE BANK
132 VINE STREET
ANYTOWN, USA 67500-0010

872919345 00178255000000003

Detach here and return upper portion with check or money order. Do not staple or fold.

Statement of Personal Credit Card Account

Retain this portion for your files.

THE BANK

Cardmember Name	Account Number	Statement Closing Date
JOE EMPLOYEE	1234-456-890	01-31-01

Statement Date: 02-01-01
Closing Date: 01-31-01
Payment Due Date: 03-01-01
Credit Limit $1,500.00
New Balance: $278.50
Credit Available: $1221.50
Minimum Payment Due: $20.00

Account Summary

Previous Balance:	+74.24	Transaction Fees:	+3.00
Purchases:	+250.50	Annual Fees:	+25.00
Cash Advances:	+0	Current Amount Due:	+250.50
Payments:	-74.25	Amount Past Due:	+0
Finance Charge:	+0	Amount Over Credit Line:	+0
Late Charge:	+0	NEW BALANCE:	$278.50

Reference Number	Sold	Posted	Activity Since Last Statement		Amount
43210987	01-03	01-13	Payment, Thank You		-$74.25
01234567	01-12	01-13	Wings 'N' Things	Anytown, USA	$25.25
78901234	01-14	01-17	Record Release	Anytown, USA	$40.00
45678901	01-14	01-17	Sports Stadium	Anytown, USA	$75.25
3210987	01-22	01-23	Tie Tack	Anytown, USA	$20.75
76543210	01-29	01-30	Electronic World	Anytown, USA	$89.25
23455678		01-30	Transaction Fees		$3.00
34567890		01-01	Annual Fee		$25.00

PAGE 1 OF 1

Data Integrity: Definition & Threats

Definition (X.800)

Data Integrity is the property that data has not been altered or destroyed in an *unauthorized* manner.

- **Key Point:** Similar to confidentiality, the notion of "unauthorized" is crucial— integrity cannot be assessed if we do not know who or what is authorized.
- **General Threats:**
  - **Corruption** by external or internal actors
  - **Unauthorized Deletion, Creation, or Modification** of data/files
  - **Insider Threats** (accidental or intentional changes)
- **Authenticity & Integrity Link:**
  - If data is altered in an unauthorized way, it is no longer *authentic*.
  - Conversely, if data lacks authenticity, its integrity is *uncertain*.

Ensuring Data Integrity: Controls

Security Controls Supporting Data Integrity:

- **Authentication & Access Control**
  - Prevent unauthorized users from modifying or deleting data
- **Cryptographic Measures**
  - Encryption or cryptographic checksums (e.g., hashing)
  - Integrity checks for data at rest and data in transit
- **Data Backups**
  - Restoring original data in case of corruption or unauthorized changes
- **Physical Security**
  - Guards, locks, restricted access to protect against physical tampering

Note

Many controls for data integrity overlap with those for confidentiality—both require managing *who* has legitimate access and *how* data is protected.

Availability

Definition (ISO/IEC 27000)

Availability is the property of being accessible and usable upon demand by an *authorized* entity.

- **Key Point:** As with confidentiality and integrity, "authorized" is crucial — if we do not know who is authorized, then it's unclear for whom the system should remain available.
- **Threats to Availability:**
  - Denial-of-Service (DoS) and Distributed DoS (DDoS)
  - Obstruction of legitimate access
  - Delays in time-critical functions
- **Security Controls:**
  - Filtering harmful traffic (firewalls, IDS/IPS)
  - Redundancy (extra servers, network links), load balancing
  - Backups and disaster recovery plans
  - Incident response capabilities to restore services quickly

Authenticity

Deepfakes and AI

Authenticity ensures that data, media, or other digital content truly originates from the claimed source.

- **Role of AI and Deepfakes:**
  - Advanced AI can generate realistic synthetic images, videos, or audio
  - Deepfakes erode trust if viewers cannot confirm the origin or legitimacy
- **Maintaining Authenticity:**
  - Digital signatures and watermarking to verify original creators
  - Provenance tracking to confirm content's chain of custody
  - AI-driven detection tools that identify manipulated or synthetic media
- **Key Takeaway:**
  - As AI evolves, organizations must invest in verification mechanisms to preserve trust and protect against misinformation.

Non-Repudiation

Definition

Non-repudiation ensures that a party in a communication or transaction cannot deny the authenticity of their signature or the sending of a message.

- **Digital Signatures**: Provide cryptographic proof of origin and integrity
- **Timestamps and Logging**: Record events in a verifiable manner
- **Accountability**: Ensures actions can be tied to specific entities
- **Use Cases**:
  - E-commerce transactions (buyers and sellers cannot deny a purchase)
  - Legal documents or contracts (signatory cannot later disown a signature)

Reliability

Definition

Reliability ensures that systems or services consistently perform their intended functions with minimal errors or failures.

- **Key Factors**:
  - Robust design and fault tolerance (e.g., redundancy, load balancing)
  - Regular maintenance, monitoring, and patching
  - Clear operational procedures and incident handling
- **Benefits of Reliability**:
  - Minimizes downtime and service interruptions
  - Preserves user trust and organizational reputation
  - Supports business continuity and high availability

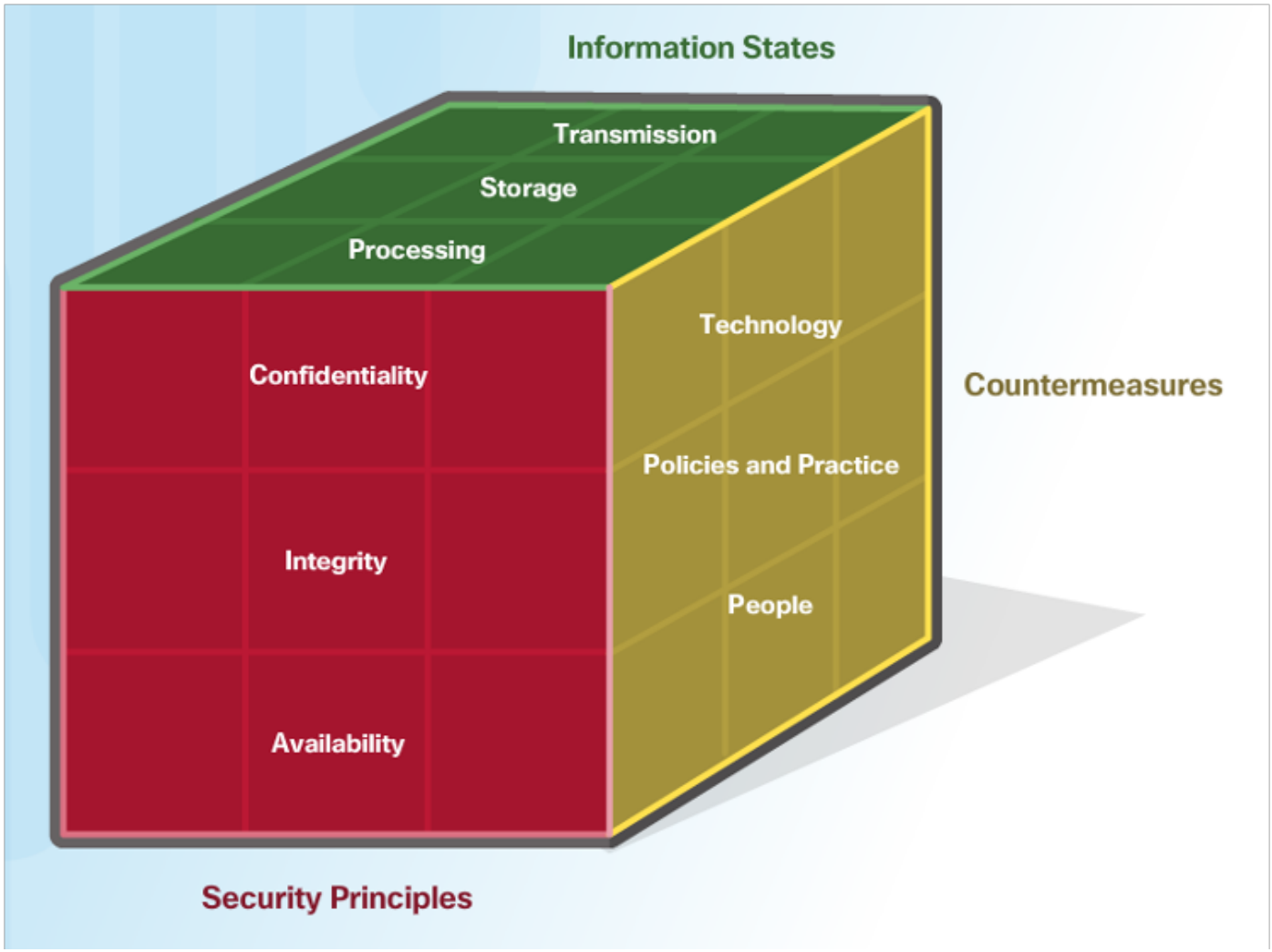
Introduction to the Cybersecurity Cube

The Three Dimensions of the Cybersecurity Cube

- **Dimension 1:** CIA Triad (Security Goals)
- **Dimension 2:** States of Data
- **Dimension 3:** Cybersecurity Countermeasures

- The **CIA Triad** addresses *what* we protect.
- The **States of Data** address *when/where* data needs protection.
- **Countermeasures** address *how* we protect the cyber world.

Introduction to the Cybersecurity Cube



Countermeasures in the Cybersecurity Cube

Countermeasures

Countermeasures (security controls) can be broadly grouped into:

- **Technology**
- **Policies & Practices**
- **People**

Other Ways to Categorize Security Controls:

- **Domain-based** (ISO/IEC 27002): *organizational*, *people*, *physical*, *technological*
- **Operational-based** (NIST SP 800-53, CIS Controls): *access management*, *training*, *network security*, *etc.*
- **ITIL "Four P's"**: *People*, *Product*, *Partner*, *Process*
- All frameworks cover many of the *same* controls but group them differently.

Countermeasures: Technology

Technological Safeguards

Hardware and Software Solutions to prevent, detect, or correct security issues.

Software-based:

- OS and database hardening (patching, secure configuration)
- Endpoint security: antivirus, host-based firewalls
- Intrusion Detection Systems (IDS), Intrusion Prevention Systems (IPS) software
- Logging and SIEM (Security Information & Event Management)

Hardware-based:

- Dedicated firewall appliances and content filters
- Hardware-based IDS/IPS
- Network monitoring/proxy devices

Countermeasures: Policies & Practices

Organizational and Procedural Safeguards

Policies, standards, guidelines, and procedures that define how to operate securely.

Security Policy:

- High-level document defining security objectives and rules of behavior
- Ensures network, data, and systems are safeguarded consistently

Standards & Guidelines:

- **Standards** specify consistent configurations, technologies, or processes that must be used
- **Guidelines** offer best practices; more flexible and not strictly mandatory

Procedures:

- Detailed, step-by-step instructions to ensure correct implementation

Countermeasures: People

The Human Factor

Awareness, Skills, and Culture are crucial to cybersecurity.

- **Security Awareness Training**:
  - Introduce best practices during onboarding
  - Reinforce knowledge via ongoing training
  - Conduct phishing simulation / social engineering assessment campaigns.
- **Human Error**:
  - Employees may not be malicious but can accidentally violate procedures
  - Insider threats can be unintentional (or deliberate)
  - Create a security culture where everyone feels responsible for safe practices

Link to ISO/IEC 27002: People controls = *personnel security measures*, including background checks, clear definitions of user privileges, and ongoing training.

Takeaways

- **Countermeasures** in the Cybersecurity Cube: Technology, Policies & Practices, People
- **Multiple Frameworks** (ISO/IEC 27002, NIST SP 800-53, ITIL, etc.) provide different ways to categorize and structure these controls
- The choice of **framework** depends on the organization's *risk profile*, *regulatory requirements*, and *industry*
- Ultimately, controls must be **risk-based** and **cost-effective** to bring cyber risk to acceptable levels

States of Data

Definition

Data can exist in three states: **Data at Rest**, **Data in Transit**, and **Data in Process**.

- Each state faces different threats to **confidentiality**, **integrity**, and **availability**.
- Specific safeguards must be in place to address these distinct threats.

Data at Rest

Definition

Data at Rest is stored data *not actively being used* by applications or processes.

Storage Examples:

- Direct-Attached Storage (DAS): e.g., local hard drives, USB sticks
- NAS (Network Attached Storage): centralized storage accessible via network

Common Threats:

- **Unauthorized Access** (theft, insider threats)
- **Physical Damage** (hardware failure, disasters)

Protective Measure Examples:

- Encryption (file or disc), Access Control, Regular Backups, Physical Security

Data in Transit

Definition

Data in Transit is data *actively moving* across a network or between devices.

Transmission Methods:

- physical transfer of removable media, ethernet, fiber optics, Wi-Fi, cellular

Threats:

- **Eavesdropping** (interception, packet sniffing)
- **Tampering** (man-in-the-middle attacks)
- **Denial of Service** (DoS, DDoS)

Protections:

- **Encryption** (TLS/SSL, VPNs)
- **Secure Protocols** (HTTPS, SFTP, SSH)
- **Firewall or IDS/IPS** to filter malicious traffic

Data in Process

Definition

Data in Process refers to data *being created, updated, or computed* by applications.

Examples of Processing:

- Data collection and Storage (*manual entry, Biometric enrolment*)
- Computation (*modifying, analyzing, encoding/decoding*)
- Output (*reports, analytics, ML algorithms*)

Threats:

- Compromise of integrity or confidentiality
- Example: hardware or software malfunctions, exposure during computation

Protections Examples:

- **Access Control** (limit who can see or modify data in use)
- **Encryption in Process** (e.g. homomorphic encryption)

Threats, Vulnerabilities, Incidents, and Impacts

- **Threat Actor:** An active entity (adversary or force of nature) that can trigger or execute a threat scenario.
- **Threat Scenario:** A sequence of steps controlled by the threat actor, potentially harming information assets.
- **Vulnerability:** A weakness (technical, process, or human) that allows a step in the threat scenario to succeed.
- **Incident:** A breach of confidentiality, integrity, or availability that results in negative impact. (consider authenticity and reliability)
- **Impact:** The resulting harm or loss (e.g. financial, reputational) following an incident.
- **Risk:** A combination of a threat exploiting a vulnerability, leading to an incident with some impact.

Threat Actor & Threat Scenario

Threat Actor:

- Can be an *intelligent adversary* (e.g. cybercriminal, hacktivist) or a *non-malicious force* (natural disaster).
- Controls or triggers the **threat scenario**.

Threat Scenario:

- A realistic sequence of actions that can exploit one or more *vulnerabilities*.
- If these actions succeed, they cause a **security incident**.
- Example: phishing emails to gain credentials, then lateral movement to steal data.

Vulnerabilities & the Vulnerability Surface

Vulnerability:

- A weakness, flaw, or defect making it likely for a threat scenario to succeed.
- Categorized as:
  - *Technical* (software/hardware bugs, misconfigurations)
  - *Process* (inadequate procedures, poor governance)
  - *Human* (susceptibility to social engineering, insider threats)

Vulnerability Surface:

- All the *attack vectors* a threat actor can leverage.
- Reducing the vulnerability surface lowers risk, but may introduce costs or usability trade-offs.

Incidents

Incident:

- A security incident is any compromise of confidentiality, integrity, or availability that negatively impacts the organization.
- Can result from *intentional acts* (e.g. adversarial attacks) or *other causes* (e.g. human error, natural disasters).
- *Cyber incidents* specifically refer to incidents caused by adversarial threat actors.

Examples of Incidents:

- Data breach due to unauthorized access
- System downtime caused by a DDoS attack
- Accidental deletion of critical files

Impacts

Impact:

- The tangible or intangible loss resulting from an incident
- Can include:
  - *Financial Loss* (lost revenue, costs of recovery)
  - *Service Disruption* (downtime, reduced productivity)
  - *Reputation Damage*
  - *Legal/Compliance* penalties
- Severity also depends on the organization's *response readiness* (e.g., backups, incident response plan).

Risk & Security Controls

Risk:

- A combination of the *likelihood* that a threat scenario will occur and the *magnitude* of the impact.
- *Risk Assessment* maps threat scenarios to vulnerabilities and estimates potential impacts.

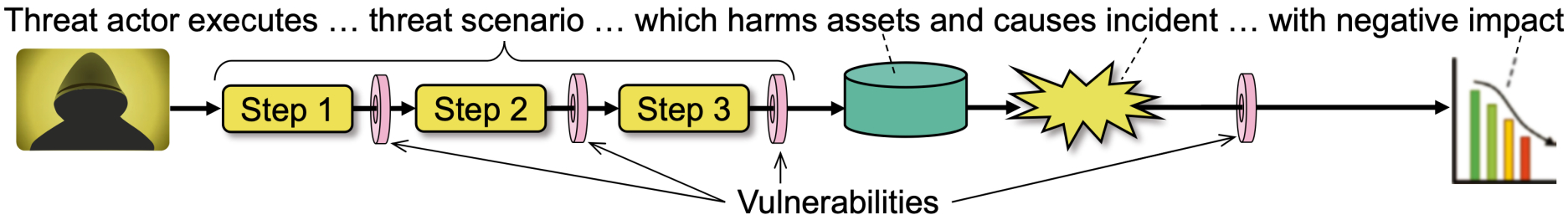
Security Controls:

- Address vulnerabilities to reduce the likelihood of incidents
- Strengthen response & recovery to limit impacts if incidents occur
- Examples: authentication, patching, backups, monitoring, incident response

Trade-offs:

- More controls often mean higher cost or reduced usability
- Must balance *risk reduction* with *business objectives*

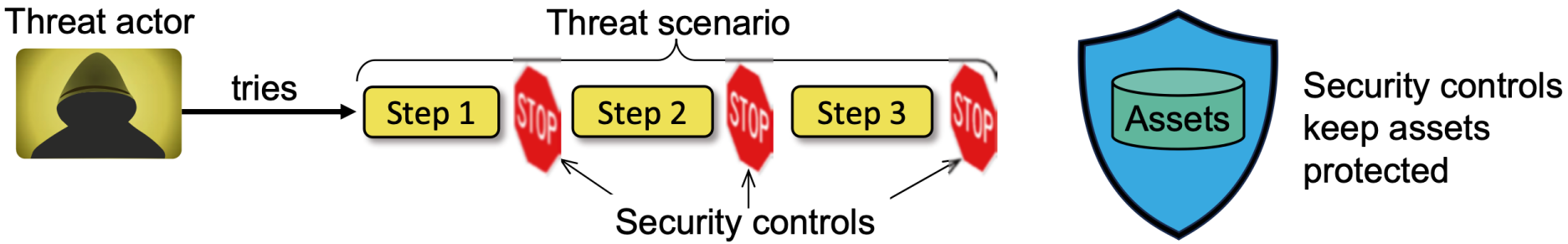
Threat Dynamics: From Actor to Impact



Key Points:

- A **threat actor** executes a *threat scenario* across multiple steps.
- **Vulnerabilities** enable these steps, allowing the actor to reach and harm **assets**.
- A successful scenario causes a **security incident** leading to negative **impact**.
- Lack of preparedness (e.g., missing backups) is also a *vulnerability* that can worsen impacts.

Security Controls Stop Threat Scenarios



Role of Security Controls:

- Implementing controls removes or reduces **vulnerabilities**.
- This prevents or disrupts key steps in a **threat scenario**, protecting assets.
- Controls also **reduce impact** by strengthening *incident response* and *recovery*.
- Examples: encryption, firewalls, backups, security policies, monitoring.

Hacker Hat Classifications


Black Hat Hacker: Malicious criminal, motivated by personal gain, disregarding the law.


White Hat Hacker: Ethical professional working within the law to find and fix vulnerabilities.


Gray Hat Hacker: Not necessarily malicious, but may ignore legal boundaries (e.g. software cracking).


Blue Hat Hacker:

- Sometimes refers to an amateur seeking revenge
- Can also mean an external security professional testing software prior to release


Red Hat Hacker: Fights black hats using aggressive or possibly illegal tactics.


Green Hat Hacker: An enthusiastic beginner, eager to learn but may cause accidental harm.

Types of Threat Actors

- **Script Kiddies** – Teenagers or inexperienced threat actors running existing scripts, tools, and exploits to cause harm, typically not for profit.
- **Vulnerability Brokers** – Hackers who discover exploits and report them to vendors, usually for prizes or rewards.
- **Hacktivists** – Grey hat hackers who rally and protest against political or social issues, often driven by ideological motives.
- **Cybercriminals** – Black hat hackers who are self-employed or work for large cybercrime organizations, primarily for financial gain.
- **State-Sponsored Hackers** – Threat actors supported by a nation-state to steal secrets, gather intelligence, or sabotage networks of foreign governments, organizations, or corporations.

Threat Actor Motivations

